

Zero Trust: From Buzzword to Action — Action Pack

Workplace Ninja Summit 2026 · Pouyan Khabazi, Cloud Security MVP

Every step of a real phish-to-cloud-takeover, and the exact Zero Trust control that closes it: what to configure, the licence it needs, who owns it, and what to switch **off**.

Licence chips: **P1/E3** you already have it on E3 · **P2/E5** needs Entra P2 / E5 · **extra SKU** a separate paid add-on, not even in E5 · **free** built-in, no licence.

The map — attack step → the control that turns it green

#	WHAT THE ATTACKER DID	MITRE	PILLAR	THE CONTROL THAT CLOSES IT
1	AiTM phish → session token stolen	T1566.002 / T1539	Identity + Endpoint	Phishing-resistant MFA (the phish) + token protection & compliant-device CA (the replay)
2	Graph / AzureHound directory recon	T1087.004 / T1526 / T1069.003	Identity	Least-privilege directory roles; restrict enumeration
3	Read secrets from Key Vault	T1555.006	Apps / workload	RBAC-only + Private Endpoint + no public network; managed identity instead of a secret
4	Sign in as the app / service principal	T1078.004	Apps / workload	Workload-identity least privilege; consent governance
5	Create a new Global Admin	T1136.003 / T1098.003	Identity	SP least privilege (can't create it) + role-assignment alerting; zero standing GA makes it a screaming anomaly
6	Elevate to User Access Administrator → Owner	T1098.003 / T1548.005	Infrastructure	PIM for Azure roles; shrink who's GA + alarm the elevate flip (you can't lock it)
7	Own/destroy resources; flip slider back to hide	T1485 / T1548.005	Infrastructure	Defender for Cloud + Azure Policy guardrails + control-plane logging
8	Impact: your data destroyed / exfiltrated	T1485 / T1567	Data + Network	Sensitivity labels + DLP; private endpoints; segmentation

None of it used a zero-day. Every step abused a default left on or a setting nobody revisited.

Pillar cards

IDENTITY

- **Configure:** phishing-resistant MFA (auth strength = WHfB / FIDO2 passkey / CBA) · PIM for every privileged role — **zero standing GA** · token protection + compliant-device CA · CAE · Identity Protection risk policies · restrict directory enumeration & user creation.
- **License:** **P1/E3** phishing-resistant MFA · Conditional Access · CAE (incl. Universal CAE strict enforcement for **Microsoft traffic**) · token protection (*native apps: Win/iOS/macOS; browser in preview*). **P2/E5** Identity Protection risk policies · PIM.
- **No E5/P2? Compensate:** phishing-resistant MFA is P1 — do it regardless; add named-location + compliant-device CA; hard-cap Global Admins (≤5); manual access reviews instead of risk automation.
- **Cheapest real upgrade:** buy **Entra P2 for admins only** (subset licensing) → PIM/JIT + risk policies for the accounts that matter, for a fraction of tenant-wide E5.
- **Owner:** Identity / IAM team · *small shop: you (automate with CA + PIM templates)*.
- **Switch OFF:** **OFF** standing Global Admin · **OFF** unrestricted directory enumeration · **OFF** SMS/voice/push-only MFA for admins · **OFF** "all users / all apps / allow" CA · **OFF** per-user MFA (move to CA) · **OFF** legacy/basic auth (*hygiene — note it did not break this attack; AiTM uses modern auth*).
- **What changes:** nobody *is* an admin — they *become* one, for a reason, then it's gone.

ENDPOINT

- **Configure:** require **compliant / hybrid-joined device** in CA (the replay lock) · **Windows LAPS** · **Credential Guard** · the **3 ASR rules** (audit → block): block LSASS credential theft, block Office apps creating child processes, block executable content from email/webmail · Intune security baselines · MAM for BYOD.
- **License:** **free/E3** compliant-device CA · LAPS · Credential Guard · ASR · baselines. **P2/E5** Defender for Endpoint **EDR** / automated investigation & response / advanced hunting. (*Defender for Endpoint P1 has no EDR — NGAV + ASR + manual response only*.)
- **No E5? Compensate:** the E3/free controls are the bulk of the win. For app allow-listing on managed fleets use **App Control for Business (WDAC)**, not Smart App Control.
- **Cheapest real upgrade:** nothing to buy — turn on **LAPS + Credential Guard + the 3 ASR rules** this week.

- **Owner:** Endpoint / MDM team · *small shop:* you + Autopilot + Intune baselines.
- **Switch OFF:** **OFF** unmanaged devices reaching corporate apps · **OFF** shared/static local-admin passwords (→ LAPS) · **OFF** LSASS credential access (→ Credential Guard + ASR) · **OFF** non-compliant / unencrypted devices.
- **What changes:** the device earns access every time — and local admin stops being one shared key.

APPS / WORKLOAD IDENTITY

- **Configure: managed identities over secrets** (no secret to steal) · Key Vault **RBAC-only + Private Endpoint + no public network + purge protection** · least-privilege service principals · consent governance (admin consent workflow, publisher verification, block risky OAuth scopes for unverified apps).
- **License:** **free** managed identities + RBAC (the better path) · **Defender for Key Vault** · **extra SKU** Workload Identities Premium (\$3/identity/mo, **NOT in E5**) for CA + risk on service principals (*single-tenant SPs only; managed identities not in scope*).
- **No E5 / no Workload ID Premium? Compensate:** managed identities + tight RBAC + secret rotation — most of the win, zero premium SKU.
- **Cheapest real upgrade:** nothing to buy — convert app-registration **client secrets** → **managed identities**. Deletes the exact thing the attacker stole.
- **Owner:** Cloud Platform / App team (secrets & least privilege) + Identity team (consent) · *small shop:* you — *managed identity everywhere*.
- **Switch OFF:** **OFF** client secrets in Key Vault / app settings · **OFF** Key Vault public network · **OFF** access-policy model (use RBAC) · **OFF** standing service-principal permissions · **OFF** user consent to any app.
- **What changes:** apps and secrets are identities — govern them, don't forget them in a config file.

INFRASTRUCTURE / CONTROL PLANE

- **Configure: PIM for Azure resource roles** (JIT Owner/Contributor, no standing Owner) · a **free Azure Monitor alert** on the elevate-access action + new Owner assignments (the deterministic catch) · **Azure Policy guardrails** (deny public IPs, enforce private endpoints, allowed locations, require diagnostics) · Defender for Cloud · control-plane logging.
- **License:** **free** Azure Policy + Azure Monitor alert · **P2/E5** PIM for Azure · **extra SKU** Defender CSPM (attack-path analysis) + Defender for Resource Manager (*paid, on top of E5; its elevate alert is anomaly-based — the free Azure Monitor alert is the tripwire*).
- **No E5/P2? Compensate:** hard RBAC (no standing Owner), the free Azure Monitor alerts on role-writes + elevate, and Azure Policy.
- **Cheapest real upgrade:** free first — the elevate/Owner alert catches step six at zero cost; then Defender CSPM on production subscriptions for the attack-path map.
- **Owner:** Cloud Platform / landing-zone team + SecOps · *small shop:* you + *one policy baseline set once*.
- **Switch OFF:** **OFF** standing Owner at subscription/root · **OFF** the elevate toggle usable by more GAs than you can name · **OFF** subscriptions with no Defender for Cloud · **OFF** tenant with no policy guardrails.
- **What changes:** cloud ownership becomes just-in-time and observable — the elevate slider stops being silent god-mode. (*You cannot disable the slider — it's inherent to Global Admin — so the control is fewer GAs + an alarm.*)

DATA *(floor, not ceiling — its own session)*

- **Configure:** Purview **sensitivity labels** on crown-jewel data · **DLP** on the obvious exfil paths · encryption follows the label.
- **Owner:** Data / Compliance · *small shop:* label your top ONE data type — *don't boil the ocean*.

NETWORK *(floor, not ceiling — its own session)*

- **Configure: Private Endpoints** (no public Key Vault / storage) · **Global Secure Access** to replace a flat VPN · segmentation.
- **Owner:** Network / Platform · *small shop:* kill public endpoints first.

Start Monday — ranked

Step 0 — measure before you change: run the read-only **Microsoft Zero Trust Assessment** against your own tenant → a scored HTML report per pillar. (*It can take >24h on a big tenant — run it and walk away.*)

```
Install-Module ZeroTrustAssessment -Scope CurrentUser
Connect-ZtAssessment      # first run: Global Admin consent
Invoke-ZtAssessment       # later runs: Global Reader + Security Reader + Exchange Admin + SharePoint Admin
```

→ github.com/microsoft/zerotrustassessment · output: **ZeroTrustReport\ZeroTrustAssessmentReport.html** (tabs: Identity / Devices / Network / Data)

What to look for on the report: (a) your **score per pillar** — where you're weakest; (b) the **high-risk failed checks** at the top — start there, not at the bottom; (c) open the **Identity tab first** — it's the pillar this attack lived in.

Then, this week — top 5: 1. Phishing-resistant MFA for admins. 2. PIM for Global Admin — kill standing GA. 3. Key Vault off public network + rotate / remove secrets. 4. The free Azure Monitor alert on the elevate-access action. 5. LAPS + Credential Guard + the 3 ASR rules.

Own it — write a name before you leave

Zero Trust without an owner fails. A **person**, not a team.

PILLAR	IDEAL OWNER	YOUR NAME
Identity	IAM / Identity team	_____
Endpoint	Endpoint / MDM team	_____
Apps / workload	Cloud Platform + Identity (consent)	_____
Infrastructure	Cloud Platform / landing-zone + SecOps	_____
Data	Data / Compliance	_____
Network	Network / Platform	_____

Small shop? The honest answer to all six may be your name — then write it. A decision you wrote down is a decision.

If prevention fails — the two detections worth having

A secret was read from a Key Vault:

```
AzureDiagnostics
| where ResourceProvider == "MICROSOFT.KEYVAULT" and Category == "AuditEvent"
| where OperationName has "SecretGet"
| project TimeGenerated, Resource, OperationName, identity_claim_appid_g, identity_claim_oid_g, CallerIpAddress, ResultDescription
| order by TimeGenerated desc
```

Someone flipped the elevate slider / took Owner *(the highest-signal line in your tenant — this is the one shown on screen in the session):*

```
// The elevate action
AuditLogs
| where OperationName == "User has elevated their access to User Access Administrator for their Azure Resources"
// New Owner/Contributor assignments
AzureActivity
| where OperationNameValue == "MICROSOFT.AUTHORIZATION/ROLEASSIGNMENTS/WRITE"
| extend RoleDefinitionName = tostring(parse_json(tostring(parse_json(Authorization).evidence)).role)
| where RoleDefinitionName in ("Owner", "Contributor")
| project TimeGenerated, Caller, RoleDefinitionName, CallerIpAddress, Scope=tostring(ResourceId), ActivityStatusValue
| order by TimeGenerated desc
```

Resources

- **Zero Trust Assessment + Workshop:** github.com/microsoft/zerotrustassessment
- **Microsoft Cybersecurity Reference Architecture (MCRA):** aka.ms/mcra
- **Slides (PDF)** + this Action Pack: github.com/pkhabazi/WpNinjaSummit26 *(slides published right after the session)*
- **Pouyan Khabazi** — Pouyan@cofend.io · [@pkhabazi](#) · [blog/podcast](#)

Assumes M365 E5 / Entra P2 as the baseline — but licensing is per-control: many fixes are P1/E3, a few are separate paid SKUs even on E5. Flagged per line above.

github.com/pkhabazi/WpNinjaSummit26

Pouyan@cofend.io · [@pkhabazi](#)